Opération Gryphon : trame du scénario d'attaque

Fil conducteur de la campagne contre Meridian Bank (domaine `meridian.local`). Palier retenu : socle + couche 2 (poste client dans le domaine). Point de départ : compte utilisateur standard sur le poste client (accès initial simulé). Objectif final : domination du domaine puis exfiltration de données fictives depuis le partage cible.

Chaque phase donne : l'intention, l'outil, la ou les techniques ATT&CK, et l'artefact laissé (à reporter dans le journal).

Hypothèse de départ (accès initial)

Le sujet te fait monter la cible, il n'y a pas de phishing réel à jouer. On pose donc un accès initial crédible et documenté : un compte utilisateur standard `meridian\jdupont` est considéré comme compromis (mot de passe obtenu hors périmètre). C'est le scénario bancaire classique : un poste bureautique tombe, l'attaquant part de là.

- Tactique : Initial Access
- Technique : T1078.002 Valid Accounts: Domain Accounts
- A documenter : poser l'hypothèse noir sur blanc dans la note de cadrage, c'est une décision de périmètre.

Phase 1 : Reconnaissance du domaine (Discovery)

But : cartographier l'AD avant de bouger, identifier les chemins vers un compte privilégié.

- Outil : SharpHound (collecteur) puis BloodHound (analyse des chemins)
- Techniques :
  - T1087.002 Account Discovery: Domain Account
  - T1069.002 Permission Groups Discovery: Domain Groups
  - T1482 Domain Trust Discovery
  - T1018 Remote System Discovery
- Artefact : rafale de requetes LDAP vers le DC, event 4662 sur DC01, fichier zip sur le poste attaquant.
- Détection : volume LDAP anormal depuis un compte standard.

Phase 2 : Accès aux identifiants (Credential Access)

But : obtenir un deuxième jeu d'identifiants, idéalement un compte de service à droits élevés.

- Outil : Rubeus ou Impacket (GetUserSPNs)
- Techniques :
  - T1558.003 Steal or Forge Kerberos Tickets: Kerberoasting (comptes avec SPN)
  - T1558.004 AS-REP Roasting (comptes sans pré-auth Kerberos, si tu en crées un pour la démo)
- Artefact : event 4769 (demande de ticket TGS) en chiffrement RC4 (0x17) sur DC01.
- Détection : 4769 RC4 vers un compte de service sensible.

Phase 3 : Escalade de privilèges (Privilege Escalation)

But : passer du compte standard à un compte à droits d'administration sur un hôte ou le domaine.

- Outil : BloodHound (lecture des chemins), exploitation manuelle du chemin le plus court
- Techniques selon le chemin que TU as construit dans l'AD :
  - T1078.002 Valid Accounts (le compte de service kerberoasté est admin local quelque part)
  - T1134 Access Token Manipulation (si abus de délégation)
  - T1484.001 Domain Policy Modification (si abus de GPO, optionnel)
- Artefact : dépend du chemin, à tracer précisément.
- Note : c'est ici que le montage de ta cible paie. Crée au moins un chemin d'escalade volontaire (ex. un compte de service membre d'un groupe à droits locaux sur le DC ou le client).

Phase 4 : Mouvement latéral (Lateral Movement)

But : rebondir du poste client vers le DC avec les identifiants obtenus. C'est le cœur de ta couche 2.

- Outil : Impacket (psexec, wmiexec), à la main pour comprendre ce que chaque commande déclenche
- Techniques :
  - T1021.002 Remote Services: SMB/Windows Admin Shares (psexec)
  - T1021.006 Remote Services: Windows Remote Management (wmiexec/WinRM)
  - T1550.002 Use Alternate Authentication Material: Pass-the-Hash (si tu as un hash NTLM)
  - T1550.003 Pass-the-Ticket (si tu as un ticket Kerberos)
- Artefact : event 7045 (service installé) + 4624 type 3 (logon réseau) + 5145 (accès partage) sur DC01.
- Détection : service au nom aléatoire créé par psexec, logon réseau suivi d'exécution.

Phase 5 : Domination du domaine (Credential Access / avancé)

But : récupérer les secrets du domaine une fois admin sur le DC.

- Outil : Impacket secretsdump
- Techniques :
  - T1003.006 OS Credential Dumping: DCSync (réplication du hash krbtgt et des comptes)
  - T1003.001 OS Credential Dumping: LSASS Memory (si accès mémoire sur un hôte)
- Artefact : event 4662 avec le droit de réplication (DS-Replication-Get-Changes) depuis un compte non-DC.
- Détection : DCSync depuis une source qui n'est pas un contrôleur de domaine. Signal fort.

Phase 6 : Persistance (optionnel, Persistence)

But : démontrer qu'un attaquant garde un accès. A faire seulement si le temps le permet, et sans rien casser (contrainte du sujet).

- Techniques :
  - T1558.001 Golden Ticket (forge d'un TGT avec le hash krbtgt récupéré en phase 5)
  - T1136.002 Create Account: Domain Account (compte de backdoor)
- Artefact : ticket Kerberos de durée anormale, création de compte hors processus RH.
- Détection : TGT avec durée de vie aberrante, 4720 (création de compte) inattendu.

Phase 7 : Collecte et exfiltration (Collection / Exfiltration)

But : atteindre l'objectif du mandat, sortir les données fictives du serveur de fichiers.

- Outil : accès SMB au partage cible, copie, transfert
- Techniques :
  - T1039 Data from Network Shared Drive
  - T1005 Data from Local System
  - T1048.003 Exfiltration Over Alternative Protocol (ou T1041 si canal C2)
- Artefact : event 5145 (accès détaillé au partage) pour des fichiers sensibles, volume de lecture anormal.
- Détection : accès massif à un partage sensible par un compte qui n'y touche jamais d'habitude.

Tableau de synthèse (kill chain)

Phase	Tactique ATT&CK	Technique principale	Outil	Hôte source -> cible
0	Initial Access	T1078.002	(hypothèse)	poste client
1	Discovery	T1087.002	SharpHound	client -> DC
2	Credential Access	T1558.003	Rubeus / GetUserSPNs	client -> DC
3	Privilege Escalation	selon chemin	BloodHound	client
4	Lateral Movement	T1021.002	Impacket psexec	client -> DC
5	Credential Access	T1003.006	secretsdump	client -> DC
6	Persistence (opt.)	T1558.001	Impacket ticketer	client -> DC
7	Collection / Exfiltration	T1039 / T1048	SMB	DC/partage -> client

---

Points de vigilance

- La chaine doit etre reproductible a l'identique depuis le depot Git. Chaque commande de ce scenario finit dans le journal avec son horodatage.
- Les phases 3 et 5 dependent de la facon dont TU as structure l'AD. Construis au montage les chemins que tu veux ensuite exploiter, sinon l'escalade n'a rien a mordre.
- La phase 6 est optionnelle et ne doit RIEN detruire (contrainte stricte du sujet).
- Chaque ligne "Detection" de ce document est le brouillon d'une regle Sigma pour le livrable final. Ne la perds pas.